

API Security IN ACTION

Neil Madden





API Security in Action

NEIL MADDEN



To comment go to [liveBook](#)

ASPOSE



Manning

Shelter Island

For more information on this and other Manning titles go to
[manning.com](#)

Copyright

For online information and ordering of these and other Manning books, please visit [manning.com](#). The publisher offers discounts on these books when ordered in quantity.

For more information, please contact

Special Sales Department

Evaluation Only. Created with Aspose.Words. Copyright 2003-2026 Aspose Pty Ltd.

Manning Publications Co.
20 Baldwin Road
PO Box 761
Shelter Island, NY 11964
Email: orders@manning.com

©2020 by Manning Publications Co. All rights reserved.

No part of this publication may be reproduced, stored in a retrieval system, or transmitted, in any form or by means electronic, mechanical, photocopying, or otherwise, without prior written permission of the publisher.

Many of the designations used by manufacturers and sellers to distinguish their products are claimed as trademarks. Where those designations appear in the book, and Manning Publications was aware of a trademark claim, the designations have been printed in initial caps or all caps.

∞ Recognizing the importance of preserving what has been written, it is Manning's policy to have the books we publish printed on acid-free paper, and we exert our best efforts to that end. Recognizing also our responsibility to conserve the resources of our planet, Manning books are printed on paper that is at least 15 percent recycled and processed without the use of elemental chlorine.



Manning Publications Co.
20 Baldwin Road Technical
PO Box 761
Shelter Island, NY 11964

Development editor: Toni Arritola
Technical development editor: Joshua White
Review editor: Ivan Martinović
Production editor: Deirdre S. Hiam
Copy editor: Katie Petito
Proofreader: Keri Hales
Technical proofreader: Ubaldo Pescatore
Typesetter: Dennis Dalinnik
Cover designer: Marija Tudor

contents

[*preface*](#)

[*acknowledgments*](#)

[*about this book*](#)

[*about the author*](#)

[*about the cover illustration*](#)

Part 1. [Foundations](#)

1 What is API security?

[1.1 An analogy: Taking your driving test](#)

[1.2 What is an API?](#)

[API styles](#)

[1.3 API security in context](#)

[A typical API deployment](#)

[1.4 Elements of API security](#)

[Assets](#)

[Security goals](#)

[Environments and threat models](#)

[1.5 Security mechanisms](#)

[Encryption](#)

[Identification and authentication](#)

[Access control and authorization](#)

[Audit logging](#)

[Rate-limiting](#)

2 Secure API development

2.1 [The Natter API](#)

[Overview of the Natter API](#)

[Implementation overview](#)

[Setting up the project](#)

[Initializing the database](#)

2.2 [Developing the REST API](#)

[Creating a new space](#)

2.3 [Wiring up the REST endpoints](#)

[Trying it out](#)

2.4 [Injection attacks](#)

[Preventing injection attacks](#)

[Mitigating SQL injection with permissions](#)

2.5 [Input validation](#)

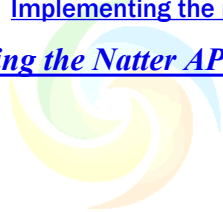
2.6 [Producing safe output](#)

[Exploiting XSS Attacks](#)

[Preventing XSS](#)

[Implementing the protections](#)

3 [Securing the Natter API](#)



ASPOSE
Your File Format APIs

[3.1 Addressing threats with security controls](#)

[3.2 Rate-limiting for availability](#)

[Rate-limiting with Guava](#)

[3.3 Authentication to prevent spoofing](#)

[HTTP Basic authentication](#)

[Secure password storage with Scrypt](#)

[Creating the password database](#)

[Registering users in the Natter API](#)

[Authenticating users](#)

[3.4 Using encryption to keep data private](#)

[Enabling HTTPS](#)

[Strict transport security](#)

[3.5 Audit logging for accountability](#)

[3.6 Access control](#)

[Enforcing authentication](#)

[Access control lists](#)

[Enforcing access control in Natter](#)

[Adding new members to a Natter space](#)

[Avoiding privilege escalation attacks](#)

Part 2. [Token-based authentication](#)

4 [Session cookie authentication](#)

- 4.1 [Authentication in web browsers](#)
 - [Calling the Natter API from JavaScript](#)
 - [Intercepting form submission](#)
 - [Serving the HTML from the same origin](#)
 - [Drawbacks of HTTP authentication](#)
- 4.2 [Token-based authentication](#)
 - [A token store abstraction](#)
 - [Implementing token-based login](#)
- 4.2 [Session cookies](#)
 - [Avoiding session fixation attacks](#)
 - [Cookie security attributes](#)
 - [Validating session cookies](#)
- 4.3 [Preventing Cross-Site Request Forgery attacks](#)
 - [SameSite cookies](#)
 - [Hash-based double-submit cookies](#)
 - [Double-submit cookies for the Natter API](#)
- 4.4 [Building the Natter login UI](#)
 - [Calling the login API from JavaScript](#)
- 4.5 [Implementing logout](#)
- 5 [Modern token-based authentication](#)
 - 5.1 [Allowing cross-domain requests with CORS](#)
 - [Preflight requests](#)
 - [CORS headers](#)
 - [Adding CORS headers to the Natter API](#)
 - 5.2 [Tokens without cookies](#)
 - [Storing token state in a database](#)
 - [The Bearer authentication scheme](#)
 - [Deleting expired tokens](#)
 - [Storing tokens in Web Storage](#)
 - [Updating the CORS filter](#)
 - [XSS attacks on Web Storage](#)
 - 5.3 [Hardening database token storage](#)
 - [Hashing database tokens](#)
 - [Authenticating tokens with HMAC](#)
 - [Protecting sensitive attributes](#)
- 6 [Self-contained tokens and JWTs](#)

6.1 [Storing token state on the client](#)

[Protecting JSON tokens with HMAC](#)

6.2 [JSON Web Tokens](#)

[The standard JWT claims](#)

[The JOSE header](#)

[Generating standard JWTs](#)

[Validating a signed JWT](#)

6.3 [Encrypting sensitive attributes](#)

[Authenticated encryption](#)

[Authenticated encryption with NaCl](#)

[Encrypted JWTs](#)

[Using a JWT library](#)

6.4 [Using types for secure API design](#)

6.5 [Handling token revocation](#)

[Implementing hybrid tokens](#)

Part 3. [Authorization](#)

7 [OAuth2 and OpenID Connect](#)

7.1 [Scoped tokens](#)

[Adding scoped tokens to Natter](#)

[The difference between scopes and permissions](#)

7.2 [Introducing OAuth](#)

[Types of clients](#)

[Authorization grants](#)

[Discovering OAuth2 endpoints](#)

7.3 [The Authorization Code grant](#)

[Redirect URIs for different types of clients](#)

[Hardening code exchange with PKCE](#)

[Refresh tokens](#)

7.4 [Validating an access token](#)

[Token introspection](#)

[Securing the HTTPS client configuration](#)

[Token revocation](#)

[JWT access tokens](#)

[Encrypted JWT access tokens](#)

[Letting the AS decrypt the tokens](#)

This document was truncated here because it was created in the Evaluation Mode.